

Sistema de Inventario de activos IITS –Revisión de Riesgos Tecnológicos

Datos de la Solicitud	
N° Solicitud: 003	Fecha de revisión: 16/4/2026
Usaria: Nereida Rodriguez (Responsable de Innovación ITS)	Actividad: Evaluación de riesgos tecnológicos de soluciones web locales
Nombre de la solución tecnológica: Sistema de Inventario de activos IITS	Nombre del revisor: Julieth Linares (Analista II)
Pruebas: Pruebas de seguridad de aplicaciones web	

Resumen ejecutivo

Durante la evaluación de seguridad realizada sobre la herramienta web **IITS**, mediante pruebas dinámicas (DAST) y análisis estático de código (SAST), se identificaron hallazgos clasificados principalmente con severidad Media, Baja e Informativa. No se detectaron vulnerabilidades de riesgo Alto o Crítico durante los análisis ejecutados.

Los hallazgos identificados están mayormente asociados a configuraciones de seguridad, exposición de encabezados HTTP, y controles de hardening, así como a observaciones de tipo informativo relacionadas con la arquitectura y gestión de sesión de la aplicación. Adicionalmente, el análisis de código identificó vulnerabilidades de

severidad **Media** y **Baja**, relacionadas principalmente con prácticas de validación y manejo de entradas

Alcance y metodología

Herramientas y fuentes revisadas:

- OWASP ZAP (evidencia y alertas HTTP)
- Snyk: Análisis de Composición de Software (SCA) para dependencias de .NET.

La Guía de Pruebas de Seguridad Web de OWASP (WSTG) se utilizaba para mapear pruebas y controles.

Tecnologías detectadas

Categoría	Tecnología
Servidor	IIS 10.0 (Windows Server)
Marco	ASP.NET

Controles de Seguridad	HSTS no configurado de forma consistente
Protocolo	HTTP/2

Resultados de la revisión

1. Hallazgos y recomendaciones detalladas

1.1. Detalle de instancias (ZAP) – Evidencia

ID	Alerta	Request (método y URL)	Parámetro	Evidencia	Recomen dación (ZAP)	Riesgo
ZAP-I-001	Cabecera Content Security Policy (CSP) no configurada	GET https://desarrollos.ve.kworld.kpmg.com/IIT SN/	Content-Security-Policy	La respuesta HTTP no incluye la cabecera Content-Security-Policy.	Asegurar que el servidor web/aplicación configure la cabecera Content-Security-Policy para	Medium

					restringir el origen de scripts, estilos y otros recursos.	
ZAP-I-002	Falta de cabecera Anti-Clickjacking	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	x-frame-options	No se identifica la cabecera X-Frame-Options ni la directiva frame-ancestors en CSP.	Configurar X-Frame-Options (DENY o SAMEORIGIN) o la directiva frame-ancestors dentro de CSP.	Medium
ZAP-I-003	El servidor filtra información de versión mediante el encabezado <i>Server</i>	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	Server	Se observa el valor Microsoft-IIS/10.0 en la cabecera Server.	Configurar el servidor web para suprimir o generalizar el encabezado <i>Server</i> .	Low

ZAP-I-004	Strict-Transport-Security Header no establecido	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	Strict-Transport-Security	No se evidencia la cabecera Strict-Transport-Security en todas las respuestas.	Configurar Strict-Transport-Security con un max-age adecuado e incluir subdominios si aplica.	Low
ZAP-I-005	El servidor divulga información mediante el encabezado <i>X-Powered-By</i>	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	X-Powered-By	Se identifica el encabezado X-Powered-By en la respuesta del servidor.	Eliminar o suprimir la cabecera X-Powered-By a nivel de servidor o framework.	Low
ZAP-I-006	Falta encabezado X-Content-Type-Options	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	x-content-type-options	El encabezado X-Content-Type-Options no está	Configurar X-Content-Type-Options: nosniff para evitar	Low

				configurado como nosniff.	MIME sniffing.	
ZAP-I-007	Respuesta de Gestión de Sesión Identificada	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	.IITS.Session	Se identifica la cookie de sesión .IITS.Session en la respuesta HTTP.	Alerta informativa . Validar que las cookies de sesión cuenten con Secure, HttpOnly y SameSite.	Informational
ZAP-I-008	Reexaminar las Directivas de Control de Caché	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	Cache-Control	Respuestas devueltas con control de caché que deben ser revisadas.	Validar que el contenido sensible no sea cacheable en clientes o proxies intermedios.	Informational

ZAP-I-009	Aplicación Web Moderna	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/	N/A	ZAP identifica la aplicación como una aplicación web moderna (Blazor).	Alerta informativa, no requiere remediación.	Informational
ZAP-I-010	Divulgación de información – Comentarios sospechosos	GET https://desarrollos.ve.kworld.kpmg.com/IITSN/_framework/blazor.server.js	N/A	Se detectan comentarios sospechosos dentro de recursos JavaScript.	Remover comentarios innecesarios en artefactos publicados en producción.	Informational

1.2. Inventario completo de hallazgos – Snyk (SAST/Code)

ID	Título	Severidad	CWE	Ubicación	Resumen
----	--------	-----------	-----	-----------	---------

SNYK-001	Path Traversal	Medium	CWE-23	IITS/Program.cs (línea: 95)	Una entrada no sanitizada proveniente de argumentos de inicio fluye hacia el método CreateDirectory, donde es utilizada como una ruta del sistema de archivos. Esto podría derivar en una vulnerabilidad de <i>Path Traversal</i> y permitir la creación de directorios arbitrarios si la entrada es manipulable.
SNYK-002	Uso de credenciales embebidas	Low	CWE-798	IITS/Services/MasterDataService.cs (línea: 36)	Se identificó el uso de credenciales embebidas directamente en el código fuente mediante la definición de una clave secreta, lo cual representa un riesgo para la

					confidencialidad de la información.
SNYK-003	Uso de credenciales embebidas	Low	CWE-798	IITS/Services/MasterDataService.cs (línea: 40)	El código contiene credenciales sensibles definidas de forma estática, lo que incrementa el riesgo de exposición de secretos en caso de acceso no autorizado al repositorio.
SNYK-004	Uso de credenciales embebidas	Low	CWE-798	IITS/Services/MasterDataService.cs (línea: 42)	Se detecta el uso de valores sensibles codificados directamente en el código, lo cual no es una práctica segura para la gestión de credenciales.
SNYK-005	Uso de credenciales	Low	CWE-798	IITS/Services/MasterDataService.cs (línea: 44)	La presencia de credenciales hardcodeadas puede facilitar su exposición y uso indebido si el

	embebidas				código es accedido por terceros.
SNYK-006	Uso de credenciales embebidas	Low	CWE-798	IITS/Services/MasterDataService.cs (línea: 46)	Las credenciales están definidas directamente en el código fuente, lo que incumple las buenas prácticas de gestión segura de secretos.
SNYK-007	Uso de credenciales embebidas	Low	CWE-798	IITS/Services/MasterDataService.cs (línea: 48)	Se evidencia la repetición de valores sensibles definidos de forma estática dentro del código de la aplicación.
SNYK-008	Validación de token antifalsificación deshabilitada	Low	CWE-352	IITS/Pages/Error.shtml.cs (línea: 9)	El método tiene aplicado el atributo IgnoreAntiforgeryToken, lo que deshabilita la protección contra ataques de <i>Cross-Site Request Forgery (CSRF)</i> y podría permitir solicitudes

					maliciosas no autorizadas.
--	--	--	--	--	----------------------------

1.3 Exposición de detalles internos en mensajes de error (CWE-209)

Durante las pruebas del formulario “*Nueva aplicación*”, al ingresar valores excesivamente largos (por ejemplo, una cadena repetida de caracteres “a...a”), la aplicación retorna un bloque de error altamente verboso que expone información interna del backend, incluyendo:

- **Nombres internos de campos/modelos** (p. ej., *Funcionalidad*, *Proveedor*, *RTO*, *RPO*, *IntegracionesRelevantes*, *DependenciasTécnicas*, *FechaAdquisicionImplementacion*, *VersionActual*, *SLA*).

Nueva aplicación

Máximo 300 caracteres.

The field Funcionalidad must be a string or array type with a maximum length of '500'.

The field Proveedor must be a string or array type with a maximum length of '300'.

The field RTO must be a string or array type with a maximum length of '100'.

The field RPO must be a string or array type with a maximum length of '100'.

The field IntegracionesRelevantes must be a string or array type with a maximum length of '500'.

The field DependenciasTecnicas must be a string or array type with a maximum length of '500'.

The FechaAdquisicionImplementacion field must be a date.

The field VersionActual must be a string or array type with a maximum length of '100'.

The field SLA must be a string or array type with a maximum length of '200'.

Nombre de la aplicación *

aa

Funcionalidad principal

aa
aa
aa

Propietario

Aplicaciones

Responsable

Guardar Cancelar

- **Reglas exactas de validación** (tipo esperado y longitudes máximas: 500, 300, 200, 100, etc.).
- Mensajes **en inglés** y con formato típico de respuesta técnica (parece una respuesta de validación sin transformación “safe” para usuario final).

Editar aplicación

The field Dependencias técnicas must be a string or array type with a maximum length of '500'.

Modelo de licenciamiento

Desarrollo Local

Costo anual estimado

Ej. 1.234,56

Fecha de adquisición / implementación

mm/dd/yyyy

Versión actual

The field VersionActual must be a string or array type with a maximum length of '100'.

SLA / Acuerdo de nivel de servicio

The field SLA must be a string or array type with a maximum length of '200'.

Autenticación

Active Directory

Estatus *

Desincorporado

Guardar

Cancelar

The screenshot shows a web form titled "Editar aplicación" with a close button (X). The form contains several fields:

- Nombre de la aplicación ***: A text input field with a placeholder "Máximo 300 caracteres."
- Funcionalidad principal**: A text input field with a validation message: "The field Funcionalidad must be a string or array type with a maximum length of '500'."
- Propietario**: A dropdown menu with "Aplicaciones" selected and a "+" button.
- Responsable**: A dropdown menu with "Aplicaciones" selected and a "+" button.
- Tipo de alojamiento**: A dropdown menu with "Mi casa" selected and a "+" button.
- Proveedor**: A text input field with a validation message: "The field Proveedor must be a string or array type with a maximum length of '300'."
- Clasificación de la información**: A dropdown menu with "Confidencial" selected.

At the bottom of the form are two buttons: "Guardar" (blue) and "Cancelar" (white).

Este comportamiento es consistente con una divulgación de detalles internos por manejo inadecuado de errores/validaciones en la capa de presentación o API.

Nota: No se extendió la validación de este comportamiento a la totalidad de la aplicación, dado que el caso identificado resultó suficiente para documentar el hallazgo, y una validación transversal de este patrón implicaba una revisión más orientada a consistencia funcional que al objetivo principal de seguridad de esta evaluación.

2) Clasificación

- **CWE-209 – Generation of Error Message Containing Sensitive Information**
(Mensajes de error que contienen información sensible del entorno o implementación, útil para un atacante en fases de reconocimiento)

Impacto principal: Divulgación de información (Confidencialidad)

Un atacante puede inferir la estructura del modelo de datos (campos, nombres, tipos), restricciones exactas (límites, tipos esperados), posibles patrones de framework/validador (pistas de stack tecnológico y/o cómo se valida), y pudiendo ser aprovechado para la enumeración de parámetros y propiedades esperadas por el backend, mapeo de contratos de API/DTOs incluso si la UI oculta ciertos campos y posible optimización de payloads para provocar fallos controlados y extraer más señales durante el *recon*.

Posible impacto secundario: Señal de riesgo de over-posting - mass assignment

Al reflejar múltiples campos (algunos potencialmente no visibles en UI), existe indicio para revisar si el backend realiza binding automático de objetos completos y acepta campos no esperados si se envían en el request.

Severidad:

- **Medium** (divulgación de información por sí sola).
- Puede escalar a **Alta** si se combina con: endpoints sensibles, exposición de stack trace/paths/IDs, o fallas de allowlist/binding.

Observaciones

Durante la evaluación de seguridad de la herramienta **IITS** se identificaron debilidades de seguridad clasificadas principalmente con severidad Media y Baja, sin evidenciarse vulnerabilidades críticas o de alto impacto inmediato.

Los hallazgos derivados de OWASP ZAP están asociados mayoritariamente a debilidades de hardening y configuración, tales como la ausencia de cabeceras de seguridad, exposición de información técnica a través de encabezados HTTP y controles preventivos incompletos del lado del navegador. Se identificaron vulnerabilidades a nivel de código, destacándose un hallazgo de Path Traversal (CWE-23) de severidad Media, así como varios hallazgos de severidad Baja relacionados con uso de credenciales embebidas (CWE-798) y deshabilitación de validación de tokens antifalsificación (CWE-352).

Durante la revisión manual se identificó un hallazgo relevante de exposición de detalles internos en mensajes de error (CWE-209). Ante el ingreso de valores excesivamente largos, la aplicación devuelve mensajes de error altamente verbosos que exponen nombres internos de campos y modelos, reglas exactas de validación y mensajes técnicos propios del backend. Este comportamiento representa una debilidad en el manejo de errores y validaciones, con impacto directo en la confidencialidad y valor para un atacante durante fases de reconocimiento.

Aunque este último hallazgo no evidencia explotación directa por sí solo, incrementa la superficie de ataque y puede facilitar la enumeración de parámetros, inferencia de contratos internos del backend y optimización de payloads maliciosos. Asimismo, sugiere la necesidad de revisar el mecanismo de *binding* de datos para descartar riesgos de over-posting o mass assignment.

Recomendaciones generales de remediación

- **Priorizar** la corrección de los hallazgos de severidad Media identificados durante la evaluación, con especial énfasis en el fortalecimiento del manejo de errores y validaciones expuesto por el hallazgo CWE-209.
- **Ajustar de forma inmediata el manejo de mensajes de error devueltos al usuario final**, de manera que estos sean genéricos, controlados y orientados al usuario, evitando exponer nombres internos de campos, estructuras de modelos, reglas exactas de validación o mensajes técnicos del framework. Los detalles técnicos completos deberán conservarse exclusivamente en los logs internos, accesibles solo para fines de operación y soporte.
- **Revisar y endurecer el proceso de validación y binding de datos en el backend**, asegurando que solo los campos explícitamente permitidos sean procesados, mitigando así riesgos potenciales de over-posting o asignación masiva de propiedades no previstas.
- Se deberán atender los hallazgos identificados por OWASP ZAP, implementando las cabeceras de seguridad recomendadas, eliminando la exposición de información técnica innecesaria y reforzando los controles del lado del navegador. En paralelo, los hallazgos de Snyk deberán ser corregidos directamente a nivel de código, eliminando credenciales embebidas y revisando configuraciones que deshabilitan mecanismos de protección como los tokens antifalsificación.
- Una vez aplicadas las correcciones correspondientes y evidenciada la mitigación efectiva de los hallazgos identificados, en particular aquellos clasificados como severidad Media, se recomienda ejecutar una **nueva validación de seguridad con Snyk**, tanto automática como manual, para confirmar que los riesgos han sido adecuadamente gestionados.

Bajo este esquema queda entonces la aprobación de la herramienta condicionada y el GO definitivo será otorgado una vez se validen las correcciones implementadas y se constate que los mensajes de error y configuraciones de seguridad ya no exponen información sensible ni debilidades relevantes

Referencias y observables

- MITRE Corporation. (s. f.). CWE-209: Generation of error message containing sensitive information. Common Weakness Enumeration.
<https://cwe.mitre.org/data/definitions/209.html>
- OWASP Foundation. (s. f.). Improper error handling. OWASP Web Application Security Risks. https://owasp.org/www-community/Improper_Error_Handling
- OWASP Foundation. (s. f.). Error handling cheat sheet. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html
- OWASP Foundation. (s. f.). Input validation cheat sheet. OWASP Cheat Sheet Series.
https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
- OWASP Foundation. (s. f.). Testing for improper error handling. OWASP Web Security Testing Guide (WSTG). <https://owasp.org/www-project-web-security-testing-guide/>
Referencia técnica complementaria: <https://deepwiki.com/OWASP/wstg/3.7-error-handling-testing>
- OWASP Foundation. (s. f.). OWASP Zed Attack Proxy (ZAP) documentation.
<https://www.zaproxy.org/docs/>
- OWASP Foundation. (s. f.). ZAP alert details: Vulnerability classification and CWE mapping. <https://www.zaproxy.org/docs/alerts/>

- <https://docs.snyk.io/scan-with-snyk/snyk-open-source/manage-vulnerabilities/fix-your-vulnerabilities>
- OWASP Foundation. (s. f.). Secure development and integration. OWASP Developer Guide. <https://devguide.owasp.org/en/02-foundations/02-secure-development/>
- National Institute of Standards and Technology. (2023). Secure Software Development Framework (SSDF) (NIST SP 800-218). <https://csrc.nist.gov/Projects/ssdf>
- OWASP Foundation. (s. f.). OWASP Software Assurance Maturity Model (SAMM). <https://owasp.org/www-project-samm/>
- OWASP ZAP Project. (2026). OWASP ZAP security assessment report (Archivo HTML: 2026-04-14-ZAP-Report-.html). Documento interno de evaluación de seguridad.
- Snyk Limited. (2026). Snyk code security report (Archivo HTML: reporte_finall.html). Documento interno de análisis estático de código y dependencias.